

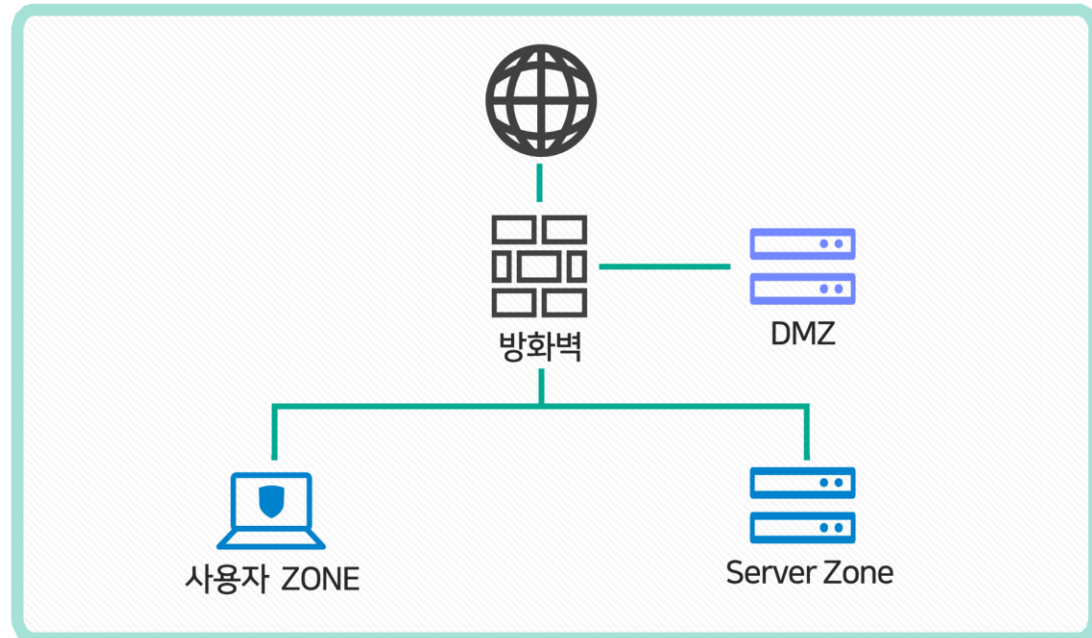
경계에서 코어(CORE)로 :

Micro-Segmentation & Extended Threat Intelligence

이글루코퍼레이션 손보형



○ 경계 기반 보안 모델



성곽형(Castle-and-Moat) 접근 방식

마치 성벽을 쌓아 외부의 적으로부터 내부를 보호하는 것과 같은 접근 방식으로, 외부의 위협으로부터 내부 네트워크를 보호하는 경계 보안에 중점

○ 경계 보안의 한계

공격 벡터의 증가



클라우드 컴퓨팅, 원격 근무, BYOD의 증가로 인해 사용자와 장비의 증가는 공격 벡터의 다양성을 통한 권한 관리의 복잡성 증가 및 기존 보안 체계에 균열 발생

우회 공격을 통한 성공률 증가



공격자는 방화벽이나 VPN과 같은 네트워크 엣지 장비의 취약점을 통해 내부 네트워크에 침투하는 사례가 빈번히 발생

인증의 한계



ID/패스워드 기반 인증은 피싱, 키로깅, 무차별 대입 공격 등 자격 증명 탈취 공격에 매우 취약

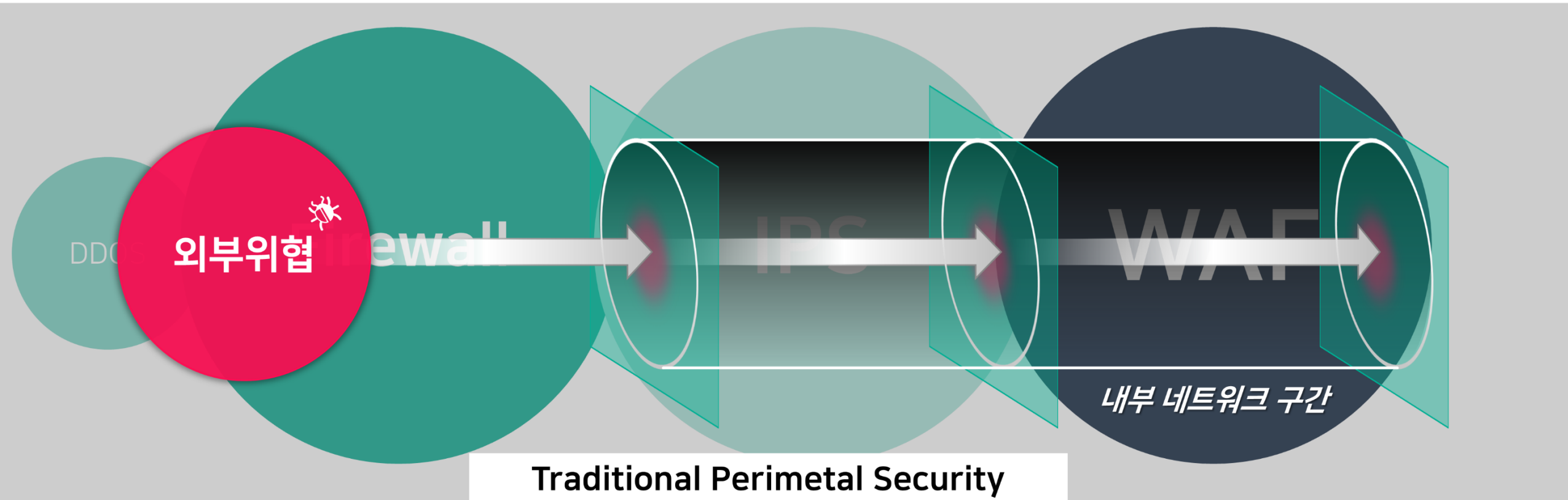
내부 신뢰 문제

☑ 핵심!

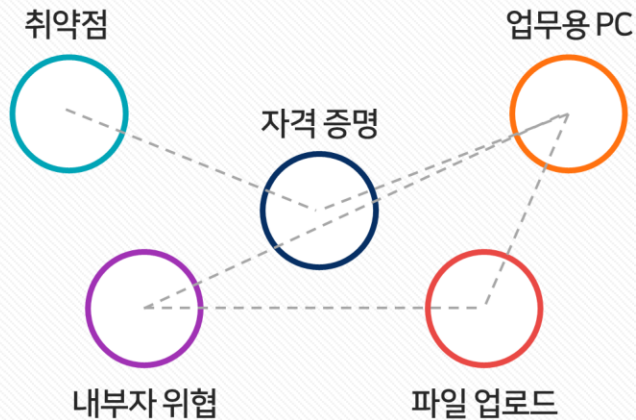


공격자가 내부로 진입하면, 전통적인 경계 보안 모델은 내부에서의 활동을 신뢰하는 경향이 있어 Lateral Movement가 가능

경계보안이라는 개념은 **애매모호**해 졌으며, 경계보안에 편중되어 있는 현대의 보안 체계에는 **더 이상 효과적인 대응에 기대감 상실**



○ 주요 공격 벡터



KISA의 분석 결과



- 악성코드에 감염된 PC 중 약 30% 이상이 일반 업무용 PC에서 발생
- 특히 북한발, 중국발 해킹 공격이 높은 비중을 차지

복잡한 권한 관리 체계

- ▲ 클라우드 도입, 원격 근무로 인한 사용자/장비 증가
- ▲ 접근 주체와 대상의 다양성으로 권한 관리의 미흡
- ▲ 비인가 접근이나 권한 오남용의 가능성을 높이는 직접적 원인

보안 솔루션 연동의 위험성

- ▲ 다양한 보안 솔루션이 PC나 서버에서 높은 권한으로 동작
- ▲ 특정 보안 솔루션의 취약점이 발견되면 모든 장비와 시스템에 대한 제어권을 획득 가능
- ▲ 단일 솔루션의 취약점으로 인한 내부망 전체에 피해를 야기시키는 대규모 보안 사고 확산 가능

내부 침투 사고사례



외부 경계를 우회하여
내부 시스템에 침투



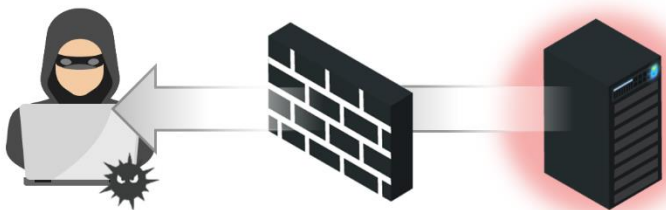
내부망이 더 이상 안전지대가
아니라는 것을 명확히 드러냄



핵심 서비스와 데이터가
외부 공격에 직접적으로 노출

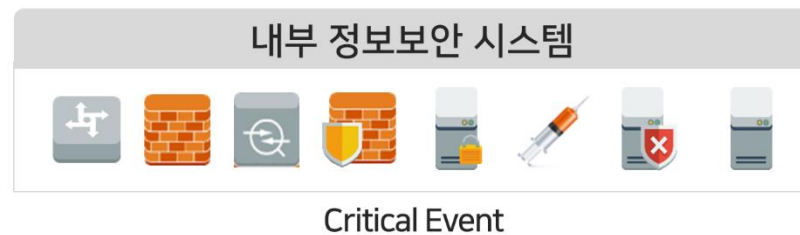
01

내부 시스템에서 외부 C&C 서버로 접속하는
Outbound Traffic에 대해 탐지



02

End-Point Solution을 대상으로
발생되는 이벤트에 대해 경보 발생 후 대응



03

내부에서 발생 되는 비 정상 Traffic 탐지
(예:비업무 시간대의 대량 Traffic 발생 등)



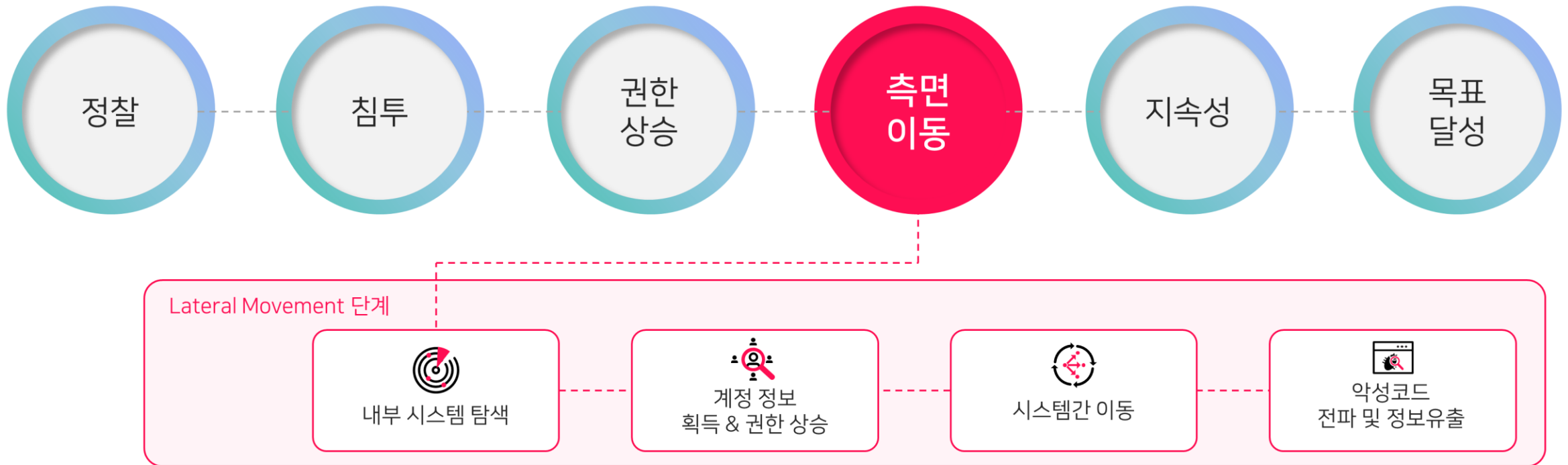
04

시스템의 비인가 접근 시도 및 행위 발생에 대한
접근제어시스템 이벤트 탐지/대응



○ Lateral Movement(측면 이동) 공격이란?

Lateral Movement는 공격자가 내부 네트워크 인프라에 침입한 후 네트워크 및 시스템의 취약성을 이용하여 전체 내부 인프라 네트워크를 장악하는 공격 방식. 공격자는 중장기 시간 동안 지속적으로 공격 범위를 확대하여 공격 목표를 달성



○ 내부 네트워크의 구조적 문제점

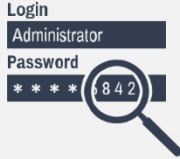
Lateral Movement 의 취약점은
내부 인프라의 무한 신뢰에서
비롯되고 있습니다.

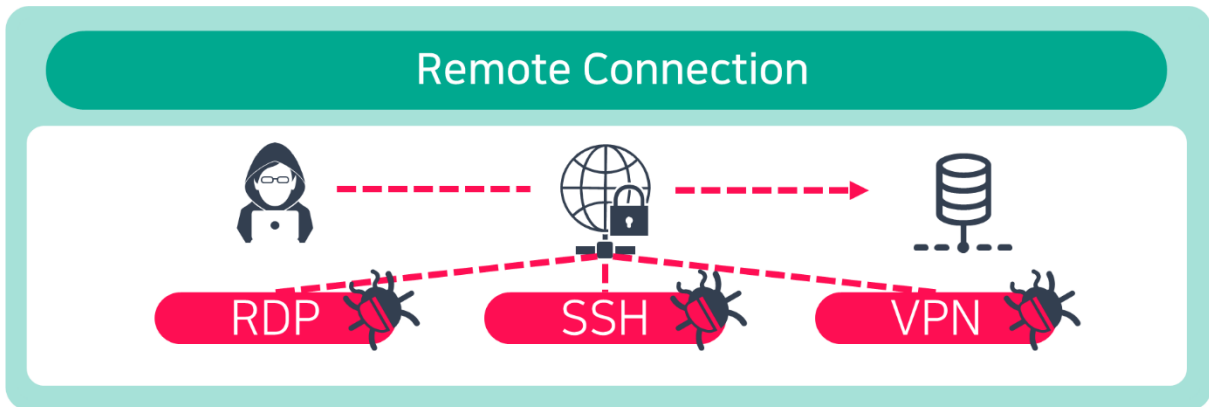


○ 전통적 보안 vs 측면 이동

전통적 보안 Perimeter Security	측면 이동 Lateral Movement
방화벽 중심 외부에서 내부로의 위협 (North-South 트래픽) 중점	내부 위협 이미 내부에 진입한 공격자가 내부 시스템 간 이동(East-West 트래픽)
신뢰할 수 있는 내부 내부 네트워크는 '신뢰할 수 있는 공간'으로 가정	제로 트러스트 모든 접근을 신뢰하지 않고 검증하는 새로운 패러다임
서명 기반 보안 시그니처 기반의 전통적 보안 솔루션	관리 도구 악용 PowerShell, WMI 등 정상적인 관리 도구를 악용

자격 증명 도용

Pass-the-Hash	Pass-the-Ticket	Memory Dumping	Key Logging	LOL(Living off the land)
				
메모리에 저장된 PW의 HASH값(NTLM 해시) 재사용을 통해 인증을 시도하는 공격 기법	Kerberos 인증 환경에서 사용되는 기법으로, 공격자가 인증 티켓(TGT, TGS)을 탈취하여 다른 서비스에 접근 시도	Mimikatz와 같은 도구를 사용하여 LSASS(Local Security Authority Subsystem Service) 프로세스의 메모리를 덤프	공격자가 사용자의 키 입력을 가로채는 기법 키로거는 대상의 키보드 입력을 기록하거나 중계하여 비밀번호를 획득	공격자는 별도의 악성코드를 설치하지 않고, 운영체제에 기본적으로 내장된 정상적인 도구와 스크립트를 악용하여 공격을 수행하는 기법



취약점을 통한 접근

 웹 서비스 파일 업로드 취약점을 통한 웹 쉘 시도	 외부로 오픈 된 취약한 서비스를 통한 접근 시도
 보안장비의 취약점을 이용한 내부 접근 시도	 사용자를 타겟 하여 악성코드 감염 후 내부 침투

○ 마이크로 세그멘테이션 정의

기본 개념

마이크로 세그멘테이션은 데이터센터, 클라우드와 같은 IT 인프라 환경의 네트워크를 **개별 워크로드 (Workload)** 수준까지 **매우 세밀하게 분할**하고, 각 분할된 세그먼트 간의 통신을 제어하는 보안 기술

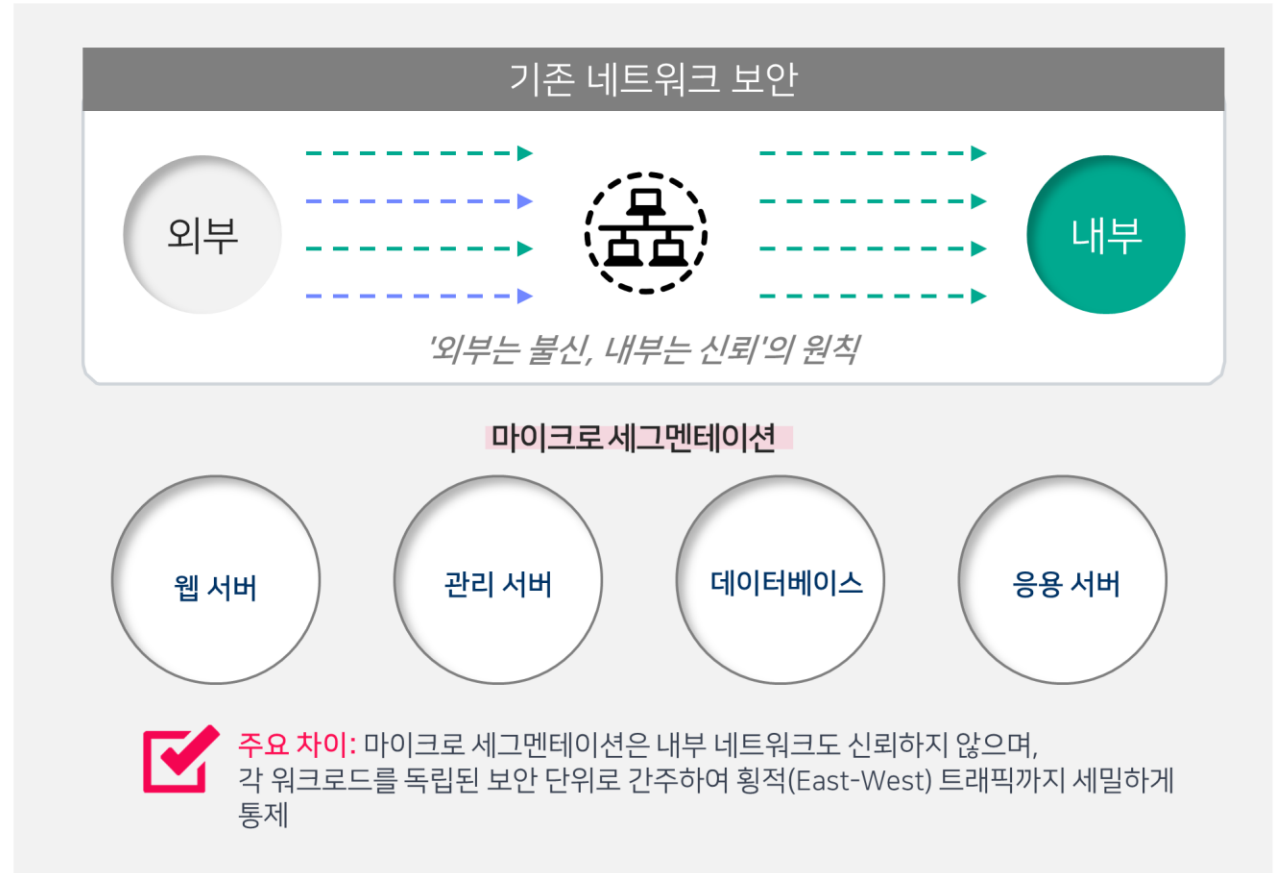


제로 트러스트 보안 모델의 네트워크 계층 구현

"아무것도 신뢰하지 않고, 항상 검증한다"는
제로 트러스트(Zero Trust) 보안 모델을 네트워크 계층에서 구현

기본적으로 **모든 통신을 차단**하고, 사전에 명시적으로
허용된 '정상적인' 통신만을 허용하는 **화이트 리스트 (Whitelist)** 방식

공격자가 시스템 내부에 침투하더라도 **측면 이동(Lateral Movement)**을
극도로 어렵게 만들어, 침해 사고 발생 시 피해 확산을 최소화

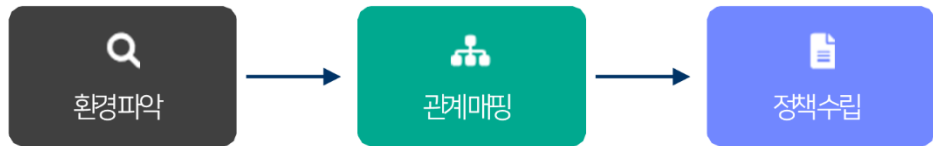




○ 기존 보안 체계 VS 마이크로 세그멘테이션

구분	기존 경계 보안 (Perimeter Security)	마이크로 세그멘테이션 (Micro-Segmentation)
방어 범위	외부 네트워크와 내부 네트워크 간의 경계 보호 - 네트워크 단위의 대규모 세분화 (VLAN, 서브넷)	데이터센터/클라우드 내부 워크로드(VM, 컨테이너, 서버, 애플리케이션) 단위의 세분화
기본 원칙	'외부는 불신, 내부는 신뢰' - 기본적으로 내부 통신 허용	'아무것도 신뢰하지 않음(Never Trust, Always Verify)'- 기본적으로 모든 통신 불허, 명시적 허용 트래픽만 허용 (제로 트러스트)
정책 적용	주로 IP 주소 및 포트 기반 - 물리적 네트워크 장비에 의존 (방화벽)	IP 주소, 포트 외에 애플리케이션, 사용자, 워크로드 특성(태그) 기반 - 소프트웨어 정의(Software-Defined) 방식으로 유연하게 적용
주요 목적	외부 공격 차단- 네트워크 간의 광범위한 트래픽 제어	내부 측면 이동(Lateral Movement) 차단- 공격 표면(Attack Surface) 최소화 - 침해 사고 시 피해 범위(Blast Radius) 축소
관리 방식	네트워크 구성 변경 시 정책 변경 필요 - 복잡하고 유연성 부족	중앙 집중식 제어, 자동화된 정책 관리- 동적인 워크로드에도 정책 자동 적용 가능
가시성	네트워크 경계 및 VLAN 간 트래픽 가시성 높음 내부 워크로드 간의 세부 트래픽 가시성 낮음	워크로드 간의 모든 트래픽 흐름에 대한 세밀한 가시성 확보 (흐름 매핑 등)
주요 솔루션	물리적 방화벽, VPN, IPS , WAF	소프트웨어 정의 방화벽(SDP), 가상 방화벽, 클라우드 네이티브 보안 플랫폼
적합 환경	전통적인 온프레미스 경계 보안 - 정적이고 변화가 적은 환경	클라우드, 가상화 환경, 컨테이너 환경, 하이브리드 클라우드 등 동적이고 복잡한 환경

○ 사전 환경 분석 중요성



1. 정보 자산 식별 및 분류

보호해야 할 핵심 자산을 식별하고 중요도에 따라 분류

- ✓ 주요 애플리케이션, 데이터베이스, 서버 등 개별 워크로드 식별
- ✓ 자산의 민감도, 비즈니스 중요도, 규제 준수 요구사항 등으로 등급 분류

2. 트래픽 흐름 분석

각 워크로드 간의 실제 통신 흐름을 파악하여 '정상적인 통신'의 기준을 정의

- ✓ 애플리케이션 디스커버리 및 매핑 도구 활용
- ✓ 워크로드 간의 Who-What-Where-When 통신 패턴 파악

3. 보안 정책 정의

분석된 트래픽 흐름을 바탕으로 화이트리스트(Whitelist) 기반의 보안 정책 수립

- ✓ "기본적으로 모든 통신을 차단하고, 명시적으로 허용된 통신만 허용"의 제로 트러스트 원칙 구현
- ✓ IP 주소뿐만 아니라 애플리케이션, 환경, 역할 등 다양한 속성 기반으로 정책 정의

구현 방법

네트워크
기반 구현

VLAN/ACL 방식
네트워크 장비의 VLAN 기능으로 ACL을 통한 IP 주소 및 포트 기반의 제어

분산 방화벽 방식
가상화 환경 or 클라우드 환경에서 워크로드에 소프트웨어 형태의 방화벽을 분산 배치하는 방식

호스트
기반 구현

에이전트 기반 방식
네트워크 변경이 필요 없으며, 워크로드 이동시에도 정책 유지 및 세밀한 보안 정책 적용 가능

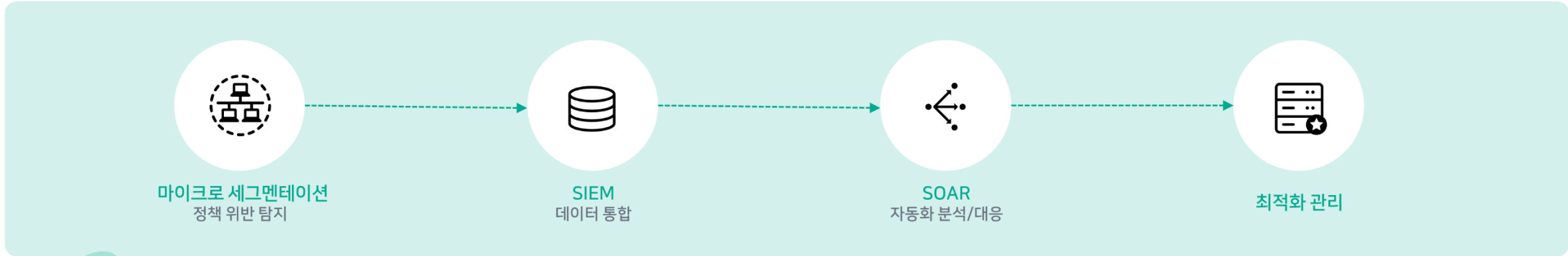
OS 내장 방화벽 접근 방식
소프트웨어 에이전트의 복잡성이 적고 OS의 보안 업데이트를 통한 최적화

클라우드
네이티브 구현

클라우드 네이티브 마이크로 세그멘테이션
클라우드 서비스 제공업체(CSP)가 제공하는
내장 보안 기능을 최대한 활용하는 방식



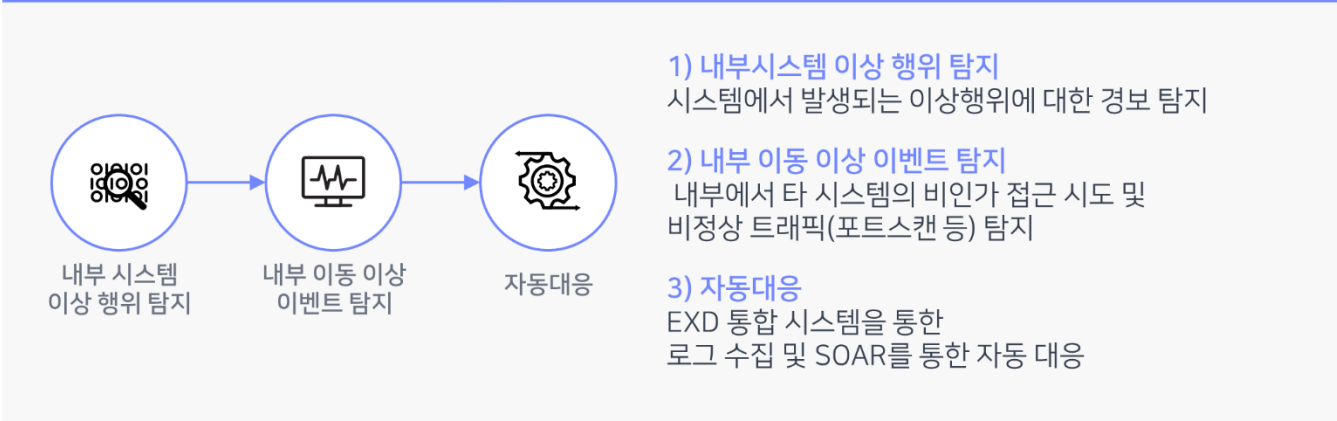
Threat Intelligence Detection

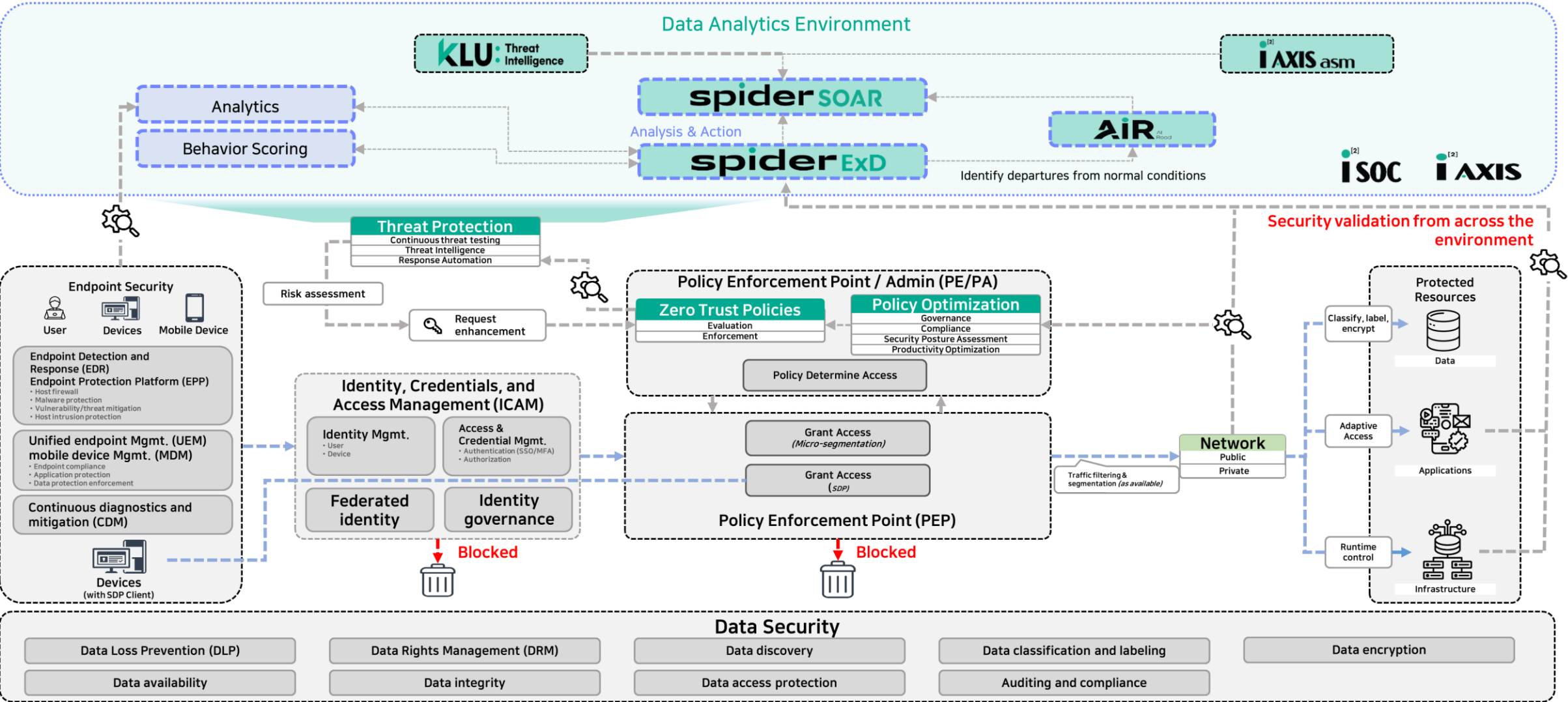


마이크로 세그멘테이션의 탐지 기능

- ❖ 정책 기반의 이상 통신 차단 및 경고: 사전에 정의된 허용 목록 (Allowlist) 정책을 기반으로 모든 통신을 검사
- ❖ 높은 신뢰도의 경고: 정상적인 통신 경로가 명확하게 정의되어 있어 정책 위반은 높은 확률로 위협 행위
- ❖ 측면 이동(Lateral Movement) 조기 탐지: 내부 네트워크로 확산하려는 시도는 대부분 정책에 위배되는 통신 유발

선제적이고 능동적인 방어 체계





[출처 : IGLOOPEDIA(<https://igloopedia.notion.site/>)]

차세대 통합보안관제 플랫폼

XDR : eXtended Detection & Response



현재

네트워크보안이벤트(FW, IPS 등) / 웹서버

현재

실시간 탐지 / CTI 연계분석 / 통계분석 / AI분석(지도학습)

현재

SOAR&Playbook / 보안시스템 자동차단

확대

엔드포인트
EDR

클라우드
서비스

통합CTI
(위협정보서비스)

확대

표준,
동적 태깅

위협헌팅

상관분석

AI분석
(이상행위)

확대

Playbook
소명처리

DevSecOps

※ DevSecOps(개발·보안·운영 통합, Development, Security, and Operations)



THANK YOU